Platform Security Briefing

Prepared for the Director, Pulse Fitness

20 April 2026

1 In one sentence

Customer data lives in a private, encrypted database behind multi-layer authentication; the Sicon link uses credentials that never leave our server and travel only over encrypted channels.

2 What "Emergent" actually does

Emergent is our deployment platform - the place the application runs. Think of it as the landlord of the building our software lives in.

- Every customer request reaches the application only over HTTPS (TLS 1.2+), the same encryption used by online banking.
- The application runs in an isolated container - other Emergent customers on the same hardware cannot see our traffic, memory, or files.
- Emergent provides the network perimeter, DDoS protection, and certificate infrastructure that secures every URL.

Important: Emergent does not have access to customer data, passwords, or Sicon credentials. They host the container; we control what runs inside.

3 How customer access is controlled

HTTPS everywhere	Every page load, API call, and file upload is encrypted in transit.
Password hashing (bcrypt)	Passwords are never stored as readable text. Even our own engineers cannot see a customer's password.
JWT session tokens	Each login produces a short-lived signed token. Stolen tokens expire automatically.
Rate-limited logins	A brute-force attempt on any account is blocked after 5 failures.
Role separation	Owner / Manager / Staff / Service Desk / Master Admin - each role can only see what it needs.
Per-organisation isolation	Every database query is filtered by organisation ID at the code level. Customer A cannot see Customer B's data.
Audit log	Every action Pulse Fitness internal staff take on a customer account is recorded - who, what, when. Cannot be edited or deleted.
GDPR right-to-erasure	Archived organisations are permanently deleted after 365 days, with 7-day advance email notice.

4 The Sicon Service link - specifically

The integration with Sicon Service is the single biggest concern customers raise, so here is exactly what happens:

- Sicon credentials live on our server, in environment variables - never in the browser. A customer using the Pulse app never sees, and never can see, the Sicon password.

- Every call to Sicon is HTTPS-only, with certificate validation. No data ever crosses the internet in plain text.
- Basic Auth over TLS - the authentication method Sicon themselves recommend. The username and password are transmitted only inside the encrypted tunnel.
- Scoped per-organisation - each Pulse customer's Sicon config is stored separately. A fault from Oxford reaches Sicon with Oxford's company ID only.
- One-way push for new faults; we poll Sicon for updates every 5 minutes. We never expose any Sicon endpoint directly to the customer's browser.
- Failure mode is safe - if the Sicon connection drops, faults queue locally and retry automatically. No data is lost.

Plain-English summary: a customer reporting a treadmill fault will see "Sent to Sicon" - but the credentials that authenticated that call never left our server and never touched their device.

5 Payment and financial data

We use Stripe for every card transaction. Stripe holds PCI-DSS Level 1 certification - the strictest standard in the industry. No card number, CVV, or full billing detail is ever stored on the Pulse platform. We only see a Stripe customer reference.

6 Worst-case analysis

Even if an attacker bypassed every perimeter layer and reached our application:

- Passwords are useless to them - bcrypt-hashed, practically un-reversible.
- Card details do not exist to steal - they live only at Stripe.
- Sicon credentials are encrypted at rest in environment configuration.
- Customer data is partitioned - compromising one account cannot by itself expose another.
- Audit log means every Service Desk action is permanently recorded. Insider misuse is traceable to an individual within hours.

7 What we commit to do next

Already on the roadmap; putting them in writing makes the commitment explicit:

- Independent penetration test before customer go-live with real equipment data.
- Two-factor authentication (2FA) for all Pulse Fitness internal staff and customer owners who opt in.
- SSO / SAML integration for enterprise customers federating their identity provider.
- Quarterly security reviews with a written summary to the Director.

8 Single point of contact

Any question from the Director's team can come directly to our engineering lead. We will respond inside one working day and share what we can without revealing anything that could itself weaken the platform.

Document version 1.0 - prepared 20 April 2026 for the Director of Pulse Fitness. For internal use only.